

EXPERIMENT: SOFTWARE COMPOSITION ANALYSIS (SCA) AND SBOM USING FOSSA

AIM

To perform Software Composition Analysis (SCA) using FOSSA to identify open-source dependencies, security vulnerabilities, and license compliance issues, and to generate SPDX and CycloneDX SBOMs.

PROCEDURE

1. Open PowerShell as Administrator and install the FOSSA CLI.
2. Verify that FOSSA CLI has been installed successfully.
3. Create a FOSSA account and generate a Full Access API token from the account settings.
4. Configure the API token in PowerShell.
5. Create a sample project and add an open-source dependency with a known vulnerability.
6. Navigate to the project directory and perform dependency analysis using FOSSA.
7. Run the FOSSA test to identify security vulnerabilities and license-related issues.
8. Open the FOSSA web dashboard and select the analyzed project. Review the Vulnerabilities section for CVE details, severity, affected packages, and remediation recommendations.
9. Review the Licenses section to identify license types and possible compliance issues.
10. Generate an SPDX SBOM using the FOSSA CLI and save it in text and JSON formats.
11. Open the FOSSA dashboard and navigate to Reports → SBOM. Select CycloneDX and download the SBOM in JSON or XML format.
12. Examine both SBOM files and compare their package names, versions, licenses, and dependency relationships.

COMMANDS

```
Set-ExecutionPolicy Bypass -Scope Process -Force; iex ((New-Object
System.Net.WebClient).DownloadString('https://raw.githubusercontent.com/fossas/fossa-cli/
master/install-latest.ps1'))
```

```
fossa --version
```

```
$env:FOSSA_API_KEY="YOUR_FULL_ACCESS_API_KEY"
```

```
mkdir fossa-lab
cd fossa-lab
```

```
npm init -y
```

```
npm install lodash@4.17.20
```

```
fossa analyze
```

```
fossa test
```

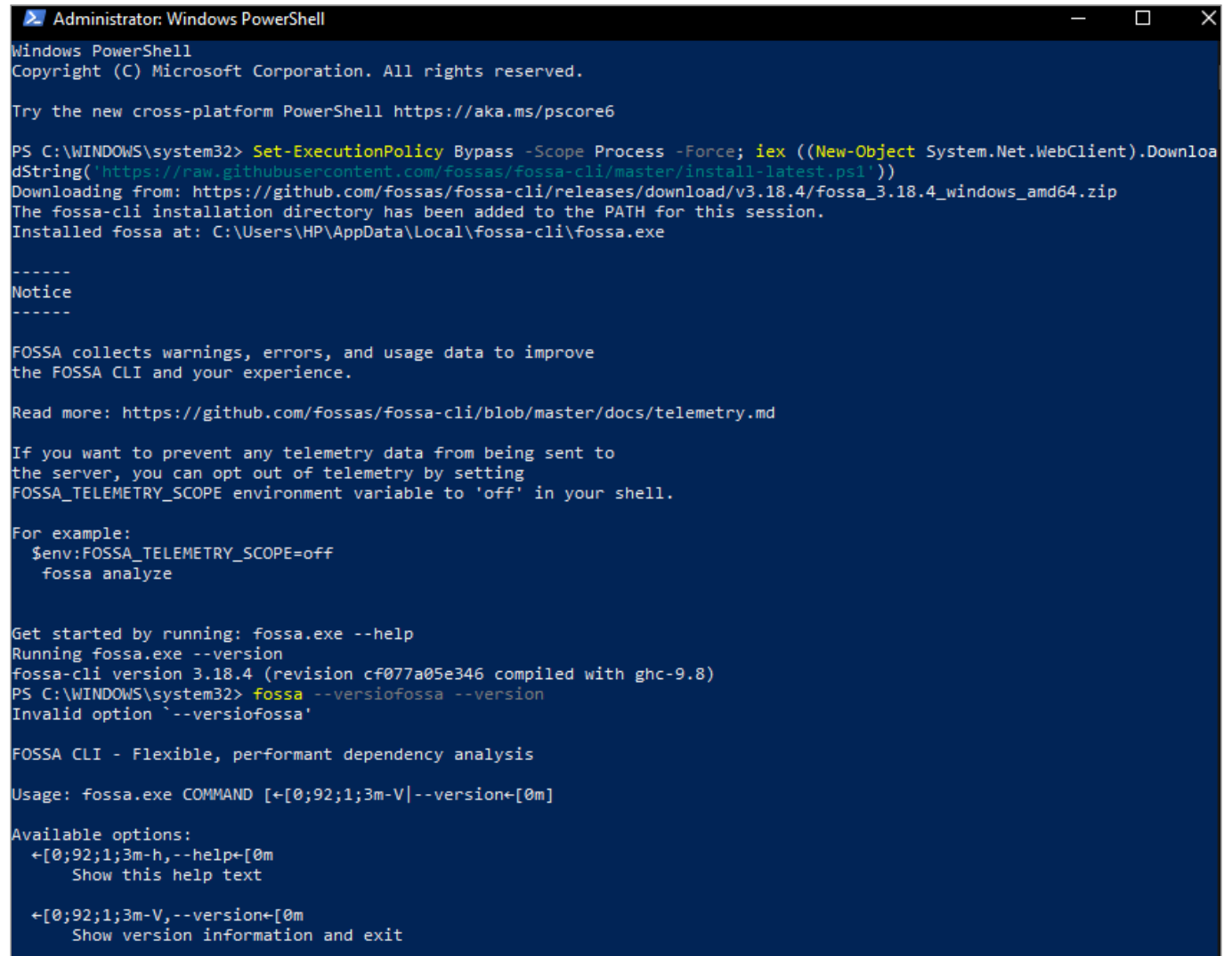
```
fossa report attribution --format spdx
```

```
fossa report attribution --format spdx > sbom-spdx.txt
```

```
fossa report attribution --format spdx-json > sbom-spdx.json
```

OUTPUT

1. FOSSA CLI Installation and Version Check



```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\WINDOWS\system32> Set-ExecutionPolicy Bypass -Scope Process -Force; iex ((New-Object System.Net.WebClient).DownloadString('https://raw.githubusercontent.com/fossas/fossa-cli/master/install-latest.ps1'))
Downloading from: https://github.com/fossas/fossa-cli/releases/download/v3.18.4/fossa_3.18.4_windows_amd64.zip
The fossa-cli installation directory has been added to the PATH for this session.
Installed fossa at: C:\Users\HP\AppData\Local\fossa-cli\fossa.exe

-----
Notice
-----

FOSSA collects warnings, errors, and usage data to improve
the FOSSA CLI and your experience.

Read more: https://github.com/fossas/fossa-cli/blob/master/docs/telemetry.md

If you want to prevent any telemetry data from being sent to
the server, you can opt out of telemetry by setting
FOSSA_TELEMETRY_SCOPE environment variable to 'off' in your shell.

For example:
  $env:FOSSA_TELEMETRY_SCOPE=off
  fossa analyze

Get started by running: fossa.exe --help
Running fossa.exe --version
fossa-cli version 3.18.4 (revision cf077a05e346 compiled with ghc-9.8)
PS C:\WINDOWS\system32> fossa --versiofossa --version
Invalid option '--versiofossa'

FOSSA CLI - Flexible, performant dependency analysis

Usage: fossa.exe COMMAND [+[-0;92;1;3m-V|--version+[-0m]

Available options:
  +[-0;92;1;3m-h,--help+[-0m]
    Show this help text

  +[-0;92;1;3m-V,--version+[-0m]
    Show version information and exit
```

2. Dependency Analysis (fossa analyze)

```
PS C:\WINDOWS\system32\fossa-lab> fossa analyze
Unable to infer project revision from VCS, using current timestamp as the revision.
[ 0 Waiting / 1 Running / 0 Completed ]
[ 13 Waiting / 4 Running / 0 Completed ]
[ 14 Waiting / 4 Running / 0 Completed ]
[ 15 Waiting / 4 Running / 0 Completed ]
[ 17 Waiting / 4 Running / 0 Completed ]
[ 19 Waiting / 4 Running / 0 Completed ]
[ 21 Waiting / 4 Running / 0 Completed ]
[ 22 Waiting / 4 Running / 0 Completed ]
[ 24 Waiting / 4 Running / 0 Completed ]
[ 25 Waiting / 4 Running / 0 Completed ]
[ 27 Waiting / 4 Running / 0 Completed ]
[ 28 Waiting / 4 Running / 0 Completed ]
[ 29 Waiting / 4 Running / 0 Completed ]
[ 31 Waiting / 4 Running / 0 Completed ]
[ 32 Waiting / 4 Running / 0 Completed ]
[ 33 Waiting / 4 Running / 0 Completed ]
[ 32 Waiting / 4 Running / 1 Completed ]
[ 28 Waiting / 4 Running / 5 Completed ]
[ 25 Waiting / 4 Running / 8 Completed ]
[ 24 Waiting / 4 Running / 9 Completed ]
[ 21 Waiting / 4 Running / 12 Completed ]
[ 20 Waiting / 4 Running / 13 Completed ]
[ 17 Waiting / 4 Running / 16 Completed ]
Analyzing npm project at C:\Windows\System32\fossa-lab\
[ 12 Waiting / 4 Running / 22 Completed ]
[ 10 Waiting / 4 Running / 24 Completed ]
[ 9 Waiting / 4 Running / 25 Completed ]
[ 8 Waiting / 4 Running / 26 Completed ]
[ 5 Waiting / 4 Running / 29 Completed ]
[ 4 Waiting / 4 Running / 30 Completed ]
[ 2 Waiting / 4 Running / 32 Completed ]
[ 0 Waiting / 4 Running / 34 Completed ]
[ 0 Waiting / 3 Running / 35 Completed ]
[ 0 Waiting / 2 Running / 36 Completed ]
[ 0 Waiting / 1 Running / 37 Completed ]

Scan Summary
-----
fossa-cli version 3.18.4 (revision cf077a05e346 compiled with ghc-9.8)
fossa endpoint server version: 4.34.102

1 projects scanned; 0 skipped, 1 succeeded, 0 failed, 0 analysis warnings
```

3. Web Dashboard Compliance & Security Overview

app.fossa.com/projects/custom%2B64154%2Ffossa-lab%5C/refs/branch/master/2026-09-11T12%3A56%3A28Z?revisionScanId=120611531

fossa-lab\ > CU Private

license scan passing security scan passing

master 2026-09-11T12:56:28Z Analyzed: Friday, September 11, 2026 at 6:26 PM GMT+5:30 CU

Summary Issues 0 Dependencies 1 Licenses 2 Reports Activity Settings

ISSUES IN MASTER

✓ All Checks Passed Run policy scan

Scan depth is limited

1

DEPENDENCIES »

2

LICENSES »

Actions

Generate Compliance Report

Generate SBOM Report

Visit API Endpoint

FOSSA ran license checks across 1 dependencies.

No issues were found.

Generate Report Share

Live Project Compliance Report

This link will always show the latest compliance report for the master branch of this project

Team Access

Activate Windows

Go to Settings to activate Windows

No teams affiliated with this project.

4. SPDX Report Generation

```
#### Files

FileName: package.json
SPDXID: SPDXRef-npm-lodash-4.18.1-package.json
Comment: extracted from SPDXRef-npm-lodash-4.18.1
LicenseConcluded: MIT
LicenseInfoInFile: MIT
FileChecksum: MD5: 7abc1a233092fc104c7af72a89c0829c
FileChecksum: SHA1: 89690ac571dcf4c9c40c842efed3f11171d07b29
FileChecksum: SHA256: e5dcffe836b6ec8a58e492419b550e65fb8cbdc308503979e5dacb33ac7ea3b7

FileName: LICENSE
SPDXID: SPDXRef-npm-lodash-4.18.1-LICENSE
Comment: extracted from SPDXRef-npm-lodash-4.18.1
LicenseConcluded: (MIT OR CC0-1.0)
LicenseInfoInFile: MIT
LicenseInfoInFile: CC0-1.0
FileChecksum: MD5: c31ca6abdd4c21b908e9436a0ba3fcf9
FileChecksum: SHA1: 3a9fcb28154139567af2cb391af4736ea3f2eed
FileChecksum: SHA256: b5037b932d38aaafc61ff212ad30e94d87a173a8edf356a18836a42290c896727

PS C:\WINDOWS\system32\fossa-lab> fossa report attribution --format sdx > sbom-sdx.txt
Unable to infer project revision from VCS, using current timestamp as the revision.

Using project name: `fossa-lab`
Using revision: `2026-09-11T12:56:28Z`
[WARN] "sdx" format may change independent of CLI version: it is sourced from the FOSSA service.
[ Waiting for build completion... ]
[ Waiting for scan completion... ]
[ Fetching attribution report... ]
PS C:\WINDOWS\system32\fossa-lab>
```

5. Dashboard SBOM Report Preview

The screenshot displays the FOSSA dashboard interface for previewing and generating an SBOM report. The browser address bar shows the URL: `app.fossa.com/projects/custom%2B64154%2Ffossa-lab%5C/refs/branch/master/2026-09-11T12%3A56%3A28Z/reports/sbom?revisionScanId=120611531&flo...`.

The main content area is titled "Preview and generate report". It features a "Preview" tab with a scrollable list of SBOM details:

- SPDXVersion:** SPDX-2.3
- DataLicense:** CC0-1.0
- SPDXID:** SPDXRef-DOCUMENT
- DocumentName:** 64154/fossa-lab/-2026-09-11T12:56:28Z
- DocumentNamespace:** 64154/fossa-lab/-2026-09-11T12:56:28Z
- Creator:** Organization: Rajalakshi Engineering College
- Creator:** Tool: FOSSA 4.34.102
- Created:** 2026-09-11T13:14:27Z
- LicenseListVersion:** 3.23
- DocumentDescribes:** SPDXRef-npm-lodash-4.18.1
- DocumentDescribes:** SPDXRef-custom-64154-fossa-lab-2026-09-11T12-56-28Z

Below the document details, the "Packages" section lists the analyzed package:

- PackageName:** lodash
- SPDXID:** SPDXRef-npm-lodash-4.18.1
- PackageVersion:** 4.18.1
- FilesAnalyzed:** true
- PackageOriginator:** Organization: NPM
- PackageSupplier:** Person: benjamin@dev.ofcr.se, john.david.dalton@gmail.com, mathias@qiwi.be
- PackageSummary:** Lodash modular utilities.
- PackageLicenseDeclared:** MIT OR CC0-1.0
- PackageCopyrightText:** OpenJS Foundation and other contributors <https://openjsf.org/>
- PackageDownloadLocation:** https://registry.npmjs.org/lodash/-/lodash-4.18.1.tgz
- PackageHomePage:** https://lodash.com/
- PackageLicenseConcluded:** NOASSERTION
- ExternalRef:** PACKAGE-MANAGER pur1 pkg:npm/lodash@4.18.1
- PackageChecksum:** MD5: f1b93901a237e0d51d3bf071d183bbef
- PackageChecksum:** SHA1: 84988ffc45752fb0652986a4dab592b1494b0c14
- PackageChecksum:** SHA256: b6249eb37c8532d9d6b5187dc02b93e924fc85c551b4aa786854befe21edb3ce

On the right side, there is a "Format" dropdown menu set to "SPDX" and a "Generate Report" button. Below this, the "Included by FOSSA" section lists the following items with checkmarks and question marks:

- ✓ Dependencies Summary
- ✓ Direct Dependencies
- ✓ Transitive Dependencies
- ✓ Unknown Dependencies
- ✓ Notice File(s)
- ✓ Package Metadata

At the bottom of the dashboard, it says "Open source management powered by FOSSA, Inc. © 2026" and "vers: 4.34.102 - revId: 8e100c13d9".

RESULT

The sample project was successfully analyzed using FOSSA SCA. The open-source dependencies, security vulnerabilities, CVE details, and license information were identified. SPDX and CycloneDX SBOMs were successfully generated and examined, providing information about the project's software components, versions, licenses, and dependency relationships.